OSNOVE INFORMACIONE BEZBEDNOSTI

SCUTUM

Uputstvo za izradu i bodovanje projekta

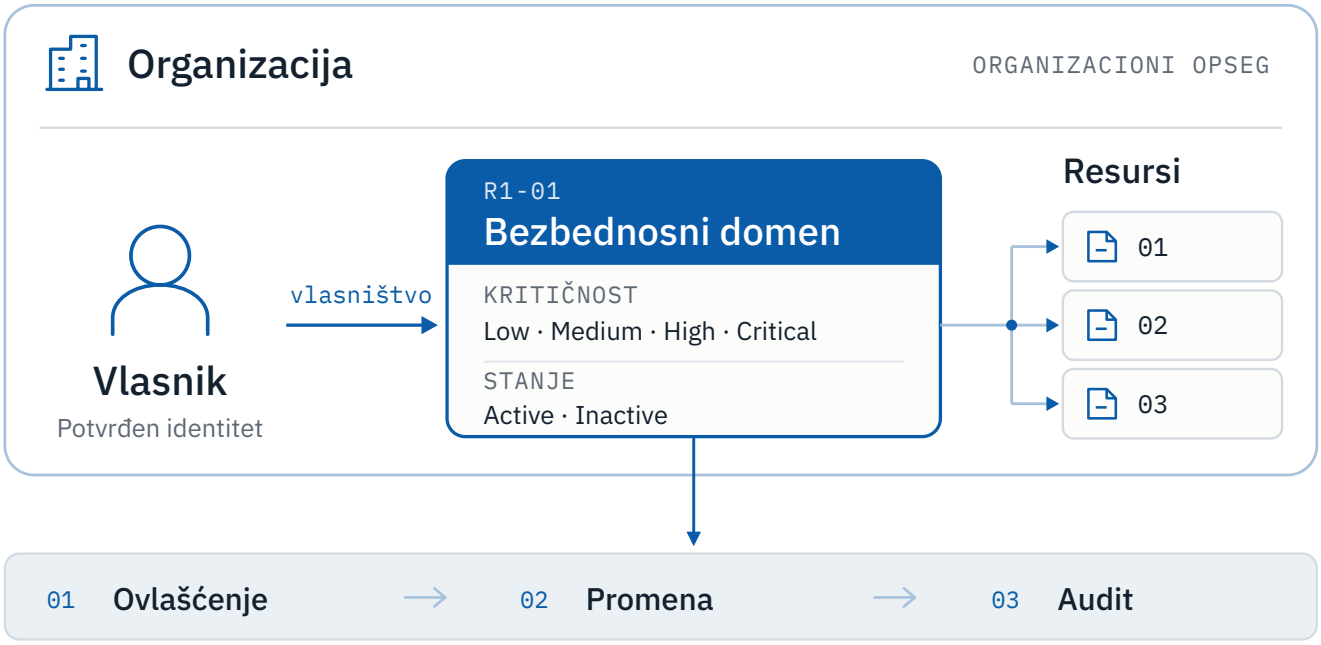
Projekat nosi najviše 30 bodova po studentu: 21 za obavezni deo (70%) i 9 za proširenja (30%). Projektna odbrana je uključena u ove bodove.

Tabela 1 Obavezni deo projekta

Kriterijum	Bodovi	Dokaz za pun broj bodova
Poslovne funkcije	8	Funkcije i pravila dodeljene celine rade
Serverska zaštita	2	Provera ovlašćenja i organizacionog opsega
Automatizovani testovi	2	Uspešni, negativni i granični scenariji
Integracija i audit	2	Javni ugovori, stvarni tok i audit dokazi
Pokretanje i dokumentacija	1	Ponovljivo okruženje, README, threat model i ADR
Individualni doprinos	3	Sopstveni zadatak, postupak rada i tehnički review
Individualna odbrana	3	Objašnjenje funkcije, zaštite i promene uslova
Ukupno obavezni deo	**21**	**15 zajedničkih i 6 individualnih bodova**

Proširenja: tri puta po 3 boda. Svako nosi 1 bod za funkciju, 1 za bezbednosne testove i 1 za sopstveni doprinos i razumevanje. Priznaju se nakon prihvatanja obaveznih funkcija i ključnih zaštita.

Tim ima 6–10 članova, preporučeno sedam, i dobija jednu celinu R1 ili R2. Oba nivoa imaju istu raspodelu bodova. Rad na R2 sam po sebi nije proširenje.



2 R1-01 Obavezne funkcije

Organizacije, bezbednosni domeni i vlasništvo vode organizacije, njihove domene, odgovorna lica i veze sa resursima. Osnovni model ima jednog vlasnika po domenu. Vlasništvo označava odgovornost, a ovlašćenje za operaciju proverava se zasebno.

Tabela 2 Poslovne funkcije R1-01, ukupno 8 bodova

Funkcija	Obim i raspodela bodova	Bodovi
Organizacija i domen	1 bod za kreiranje sa validnim podacima. 1 za trajno čuvanje i ponovni pregled, uz odbijanje nepoznate organizacije. Lista prikazuje samo dozvoljeni opseg.	2
Vlasnik	1 bod za dodelu potvrđenog identiteta. 1 za promenu vlasnika i odbijanje nepostojećeg ili nedozvoljenog identiteta, uz očuvanje prethodnog vlasništva.	2
Povezivanje resursa	1 bod za povezivanje postojećeg resursa. 1 za proveru pripadnosti, vlasništva ili odobrenog sistemskog scope-a i jedne aktivne veze. Nepoznat resurs i inactive domen odbijaju se.	2
Kritičnost	0,5 boda za trajnu promenu. 0,5 za dopuštanje samo vrednosti Low, Medium, High i Critical, bez izmene stanja pri neispravnom zahtevu.	1
Deaktivacija	0,5 boda za trajni status Inactive. 0,5 za zabranu novih veza, uz očuvanje domena, istorije i postojećih veza za ovlašćen pregled.	1
Ukupno	**Pet poslovnih funkcija**	**8**

Minimalni obim rešenja

Organizacija ima ID, naziv i status. Domen ima ID, organizaciju, naziv, vlasnika, kritičnost i status `Active` ili `Inactive`. Veza čuva ID resursa, ID domena i vreme povezivanja. Vlasnik domena ne postaje automatski vlasnik njegovih resursa.

Implementiraju se šest komandi iz Tabele 2, gde se organizacija i domen kreiraju zasebno, i dva pregleda: detalj i lista domena. Lista ima najviše 50 zapisa po zahtevu i nastavak pregleda. Svaka promena trajno se čuva. API demonstracija je dovoljna, a poseban frontend, ponovna aktivacija i migracija resursa nisu obavezni.

Pravila koja se proveravaju

Identitet aktera i njegov opseg dolaze iz validiranog serverskog konteksta. Klijentski `actorId` ili `organizationId` ne potvrđuju pravo pristupa. Neuspešna komanda čuva prethodno stanje. Odgovori imaju stabilne kodove i ne otkrivaju tuđe podatke. Dupla veza se odbija, a konkurentne izmene ne smeju neprimetno prepisati drugu promenu.

R1-01 koristi javne ugovore R1-02 za resurse, R1-03 za identitete, R1-05 za dozvole i R1-09 za audit. Ne pristupa njihovim tabelama. Do povezivanja se koriste testni adapteri sa uspešnim i neuspešnim odgovorima.

Demonstracioni podaci: dve organizacije sa po dva domena, najmanje tri identiteta različitih prava i tri resursa. Obuhvatiti pristup tuđem i deaktiviranom domenu.

3 R1-01 Provere i primer rada

Tabela 3 Tehnički i bezbednosni kriterijumi, ukupno 7 bodova

Kriterijum	Obim i raspodela bodova	Bodovi
Serverska zaštita	1 bod za ovlašćenja nad svim čitanjima i izmenama. 1 za izolaciju organizacionog opsega, uključujući direktan API poziv na tuđi ID.	2
Testovi	1 bod za uspešne tokove i granice: nepoznate reference, kritičnost, duple veze, paginacija i konflikti. 1 za odbijene bezbednosne pozive, inactive domen i očuvano stanje.	2
Integracija i audit	1 bod za ugovorne testove i stvarni tok sa susednim modulom. 1 za audit promene vlasnika i događaje kritičnosti i deaktivacije, bez tajni.	2
Pokretanje i dokumentacija	0,5 boda za novi klon, skladište i testne podatke. 0,5 za README, threat model i ADR značajne odluke.	1
Ukupno	**Sa 8 funkcionalnih i 6 individualnih bodova: 21**	**7**

Test mora pasti ako se ukloni kontrola koju proverava. Nedostupan susedni modul prijavljuje se odmah, uz ugovor, adapter i dokaz pokušaja integracije. Nastavni tim utvrđuje odgovornost i vrednovanje tog dela.

Primer: promena vlasnika

D1 je domen organizacije A, sa vlasnikom V1. A1 sme da dodeli aktivnog vlasnika V2 iz dozvoljenog opsega. B1 iz organizacije B nema pristup. Poziv i ID-jevi su ilustrativni.

```HTTP
PUT /api/security-domains/D1/owner
{ "ownerIdentityId": "V2" }
```

Server proverava aktera, opseg, pravo izmene i V2, pa dosledno čuva promenu i audit dokaz. Jedno prihvatljivo rešenje čuva promenu i događaj u istoj lokalnoj transakciji, uz audit adapter. Uspešan odgovor ne sme prikriti izgubljen dokaz.

Tabela 4 Dokazi za promenu vlasnika

Poziv	Očekivani rezultat
A1 dodeljuje V2	Vlasnik je V2, a audit potvrđuje promenu V1 → V2
B1 šalje isti zahtev	Odbijanje, vlasnik ostaje V1, bez otkrivanja tuđih podataka
A1 navodi nedozvoljen V2	Odbijanje i očuvano vlasništvo V1
Akter nije potvrđen	Operacija se ne izvršava

Svaki test počinje vlasništvom V1. Audit sadrži vreme, aktera, radnju, cilj, starog i novog vlasnika, ishod, correlation ID i oznaku osetljivosti. Lozinke i tokeni se ne upisuju.

Threat model sažeto povezuje zaštićeno vlasništvo, granicu klijent-server, pokušaj neovlašćene izmene, proveru dozvole i opsega i negativni test.

4 R1-01 Proširenja

Tri proširenja nose do 9 bodova: po 1 za funkciju, bezbednosne testove i individualni doprinos sa objašnjenjem. Osnovni tokovi i zaštite moraju ostati ispravni.

Hijerarhija domena, do 3 boda

Domen ima najviše jednog roditelja iz iste organizacije. Potrebni su trajno čuvanje veze, prikaz stabla i promena roditelja. Najviše su tri nivoa, koren je prvi. Promena roditelja čuva ograničenje dubine za celo podstablo.

Testovi potvrđuju odbijanje ciklusa, samoreference, tuđe organizacije, nedozvoljene dubine i deaktivacije roditelja sa aktivnom decom. Položaj u stablu ne dodeljuje prava pristupa. Nasleđivanje dozvola nije deo proširenja.

Delegirani vlasnik, do 3 boda

Ovlašćeni direktni vlasnik delegira imenovane operacije drugom aktivnom identitetu u istoj organizaciji, za jedan domen i konačan vremenski interval. Implementiraju se kreiranje, korišćenje, pregled i prevremeno ukidanje.

Delegat ne menja vlasnika, ne delegira dalje i ne proširuje svoj opseg. Osnovna provera dozvole ostaje obavezna. Pri svakom pozivu proveravaju se istek i ukidanje. Negativni testovi pokrivaju ta ograničenja, uz kontrolisan sat i relevantan audit.

Zajedničko vlasništvo, do 3 boda

Domen ima dva ili tri direktna vlasnika. Za promenu skupa vlasnika i deaktivaciju potrebne su potvrde dva različita trenutna vlasnika nad istim zahtevom. Izmena zahteva poništava potvrde, a delegat ne može biti drugi potvrđivač. Domen zadržava najmanje dva vlasnika. Prelazak na jednog nije obavezan, a postojeći osnovni domeni sa jednim vlasnikom ostaju funkcionalni.

Testovi proveravaju nedovoljnu ili ponovljenu potvrdu, neovlašćeno odobravanje i izmenjen zahtev. Odluke se auditiraju.

Priznavanje bodova

Student za svako proširenje pokazuje svoju implementaciju, izvršivi test ili tehnički review sa konkretnom proverom ili ispravkom. Bez tog doprinosa dobija **0 bodova za to proširenje**, i kada ga tim uspešno demonstrira. Za svih 9 bodova učestvuje u sva tri proširenja. Samo prisustvo ili neodređena review poruka nisu dovoljni.

Svaki kriterijum projekta dobija nula, polovinu ili pun broj bodova, uz obrazloženje. Primer hijerarhije: veza roditelj-dete radi, a promena roditelja nije završena, funkcija nosi 0,5. Ispravne kontrole uz nedostajući test ciklusa nose 0,5, a proverljiv doprinos sa objašnjenjem 1, ukupno 2 boda. Zaobilazak ključne zaštite zahteva ispravku.

Drugo proširenje može se raditi samo uz prethodno odobrenje nastavnog tima i objavljene uporedive kriterijume. Proširenja nisu dodatni predispitni bodovi izvan projektnih 30.

5 Individualni rad i podela zadataka

Tabela 5 Individualnih 6 bodova, odvojeno za svakog člana

Kriterijum	Dokaz za pun bod	Bodovi
Realizacija zadatka	Sopstveni kod ili izvršivi bezbednosni test povezan sa zahtevom	1
Postupak rada	Povezani zadatak, feature grana, PR i rezultat provera	1
Tehnički review	Konkretna provera, problem ili obrazložena potvrda uz test	1
Objašnjenje funkcije	Ulaz, izlaz, promena stanja i odgovornost sopstvenog koda	1
Objašnjenje zaštite	Pretnja, kontrola, negativni test i očekivani rezultat	1
Primena znanja	Obrazloženje promene uslova ili posledice uklanjanja kontrole	1
Ukupno	**Prva tri kriterijuma: doprinos. Poslednja tri: odbrana.**	**6**

Svaki član, uključujući koordinatora, ima tehnički zadatak. Rad u paru zahteva vidljive odgovornosti oba člana. Broj commit-a, linija koda ili samo pisanje dokumentacije nisu dokaz dovoljnog doprinosa. Plagijat i lažni doprinos uređeni su Pravilima polaganja.

Tabela 6 Primer podele R1-01 na sedam članova

Član	Primarni zadatak	Dokaz realizacije
1	Organizacije, domeni i pregledi	Kreiranje, trajno čuvanje i nepoznata organizacija
2	Vlasnik i identity adapter	Promena vlasnika i nedozvoljen identitet
3	Veze i asset adapter	Ispravna veza, duplikat i tuđi resurs
4	Kritičnost i deaktivacija	Neispravna vrednost i novi resurs na inactive domen
5	Ovlašćenja i opseg	Direktan neovlašćen poziv i tuđi domen
6	Audit i integracioni tok	Tačan događaj i povezivanje sa susednim modulom
7	Ugovorni i regresioni testovi, seed	Izvršivi testovi, adapteri i ponovljivo okruženje

Svako testira sopstveni deo i pregleda promenu drugog člana. U timu od šest zadaci se spajaju, a u većem se razdvajaju, uz samostalan tehnički rezultat svakog člana.

Proširenja mogu primarno voditi članovi 1 i 4 za hijerarhiju, 2 i 5 za delegaciju, 3 i 6 za zajedničko vlasništvo, a 7 za ugovorne i regresione testove. Svakom članu se dodeljuje i konkretan test ili review na ostalim proširenjima koja brani.

6 Predaja, odbrana i obračun

Predaje se commit ili Git tag verzije dostupne u zajedničkom repozitorijumu, sa uspešnim build i test proverama. Rad se vodi kroz `Tapiz task → feature branch → PR → CI i review → DONE`. Studentski direktan push na `main` nije dozvoljen.

Šta se predaje

1. Kod, javni ugovori i konfiguracija bez tajni.
2. README sa komandom za build, test i pokretanje, pripremom skladišta i testnim podacima.
3. Testovi i rezultat CI-ja, sažet threat model i ADR sa razlozima i posledicama značajne odluke.
4. Evidencija članova, zadataka, PR-ova, review-a i doprinosa proširenjima.

Podrazumevana tehnologija je .NET/C#, uz razdvojene odgovornosti domena, aplikacionog sloja i adaptera. Druga tehnologija zahteva odobrenje i interoperabilnost. Početni repozitorijum i šabloni su na github.com/owlCoder/scutum.

Kontrolne tačke i odbrana

Tabela 7 Napredak posle svake druge računarske vežbe

Tačka	Šta treba pokazati
P1	Podela rada, model i threat model, ugovor i prvi slučaj upotrebe sa negativnim scenarijem
P2	Najmanje polovina obaveznih funkcija, zaštita, negativni i ugovorni test
P3	Sve obavezne funkcije i zaštite, audit i testovi, stvarna integracija ili prijavljena spoljašnja blokada
P4	Ponovljivo rešenje, dokazi, demonstracija i individualna provera, sa odvojenom ocenom proširenja

Na odbrani pokazati poslovne funkcije, promenu vlasnika sa audit-om, odbijen pristup iz druge organizacije sa očuvanim stanjem, zabranu nove veze na inactive domen, testove i integracioni tok. Proširenja se demonstriraju odvojeno. Svaki član objašnjava svoj deo i odgovara na promenu uslova.

Za neispunjenu kontrolnu tačku moguće je umanjenje do 5 bodova prema Pravilima polaganja, uz navedenu obavezu, studenta i iznos. Nerealizovano opciono proširenje nosi 0 i nije kašnjenje obaveznog dela.

Konačni bodovi

$$P = \max(0, T + I + E - D)$$

T je zajednički deo, najviše 15, I individualni, najviše 6, E priznata proširenja, najviše 9, a D obrazloženo umanjenje. Primeri: **15 + 6 = 21**, **15 + 6 + 9 = 30**, **14 + 4,5 + 6 = 24,5**. Studenti iz istog tima mogu ostvariti različite bodove.

U prvoj realizaciji obuhvaćeni su R1-01 do R1-13 i R2-01, R2-02, R2-04, R2-05, R2-07, R2-08 i R2-09. R3 nije obuhvaćen. Funkcionalni bodovi drugih celina raspoređuju se pre rada sa istim zbirom od 8, prema njihovim obaveznim zahtevima.

Za detaljne zahteve merodavna je Projektna specifikacija SCUTUM. Datumi, prisustvo, eliminacioni test, usmeni ispit i ostali načini polaganja uređeni su Pravilima polaganja i zvaničnim obaveštenjima.